ESATIC
Module BC01 · Audit des infrastructures et conformité

TP 2

Simulation d'analyse de vulnérabilités

Chapitre 3 — Outils et techniques d'audit — Exercice 3 du module

Module	Audit des infrastructures et conformité (BC01), ESATIC
Cible principale	srv-linux (10.10.20.15), serveur Ubuntu 22.04.5 LTS du laboratoire · sous-réseau exploré : 10.10.20.0/24
Outils	Nmap 7.99 (scripts NSE, moteur vulners) · Greenbone/OpenVAS 25.04 (GMP 22.7), configuration « Full and fast » · apt changelog et debsecan (validation)
Période des relevés	Nmap : 24/09/2026, 00:53 à 00:55 UTC OpenVAS : 24/09/2026, 14:50 à 15:29 UTC
Cadre légal	Toutes les commandes ont été exécutées sur le périmètre du laboratoire (loi n° 2013-451)
Contenu du dossier	Rapport, captures d'écran, sorties Nmap, empreintes SHA-256, rapports OpenVAS au format XML (annexes A à D)

Synthèse managériale

Résultat global. Le serveur srv-linux a été analysé avec Nmap puis avec OpenVAS, en scan non authentifié et authentifié. Aucune faille exploitable depuis le réseau n'a été confirmée parmi les trois vulnérabilités étudiées : deux (OpenSSH et Apache, pourtant affichées à 8.1 et 9.8 de CVSS) sont des faux positifs corrigés par rétroportage, la troisième (sudo) est un vrai positif de risque modéré.

Apport de l'authentification. Sans identifiants, OpenVAS affiche une sévérité maximale de 2.6 (faible) ; avec identifiants, elle monte à 5.5 (moyenne) : le scan non authentifié sous-estime donc le risque.

Décision attendue. Mettre à jour sudo, qualifier puis corriger les alertes noyau (VMScape, TSA), durcir SSH et les horodatages, enregistrer les deux faux positifs dans le registre de suivi, puis refaire un scan authentifié pour vérifier (plan d'actions, tableau 9).

1. Objectif

Conduire une analyse de vulnérabilités sur le réseau du laboratoire : découverte des hôtes et services avec Nmap, scan de vulnérabilités avec OpenVAS en mode non authentifié puis authentifié, puis documentation de trois vulnérabilités avec identification du CVE, du score CVSS, de la présence éventuelle au catalogue CISA KEV, du caractère réel ou non (faux positif) et d'une mesure corrective.

2. Périmètre et méthodologie

Cible principale : srv-linux (10.10.20.15), serveur Ubuntu du laboratoire. **Sous-réseau exploré :** 10.10.20.0/24 (figure 1).

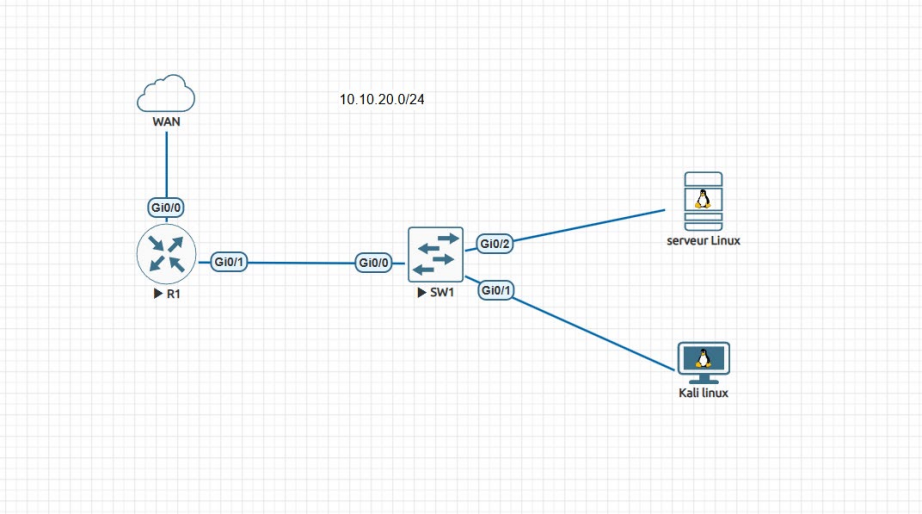


Figure 1 — *Topologie du laboratoire : R1 (10.10.20.1), SW1 (10.10.20.2), srv-linux (10.10.20.15) et Kali Linux (10.10.20.10), machine d'audit.*

Outils utilisés : Nmap 7.99 (découverte et scripts NSE de détection de vulnérabilités) ; Greenbone/OpenVAS 25.04 (scanner de vulnérabilités, configuration « Full and fast ») ; vérification complémentaire par consultation des changelogs Ubuntu (apt changelog) et de debsecan sur la cible.

Compte d'audit utilisé pour le scan authentifié : auditeur, compte SSH dédié à l'audit, déjà présent sur srv-linux (identifiant OpenVAS commenté « Compte lecture seule »). Sa connexion a été vérifiée au préalable (figure 2).

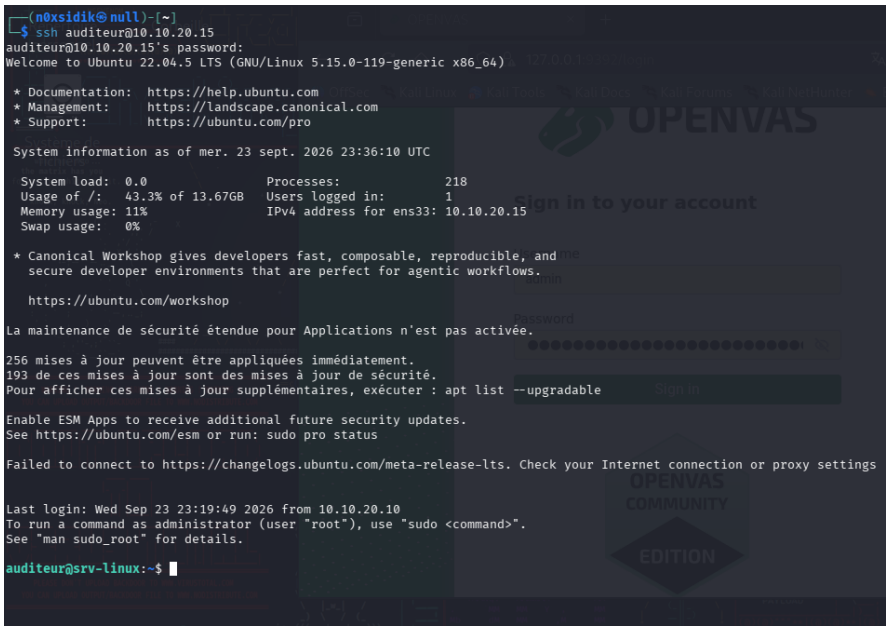


Figure 2 — *Vérification préalable de l'accès SSH du compte auditeur sur srv-linux (23/09/2026, 23:36 UTC).*

> **Remarque.** Ce compte dispose de droits sudo (utilisés pour Lynis lors du TP 1). Pour qu'il soit réellement en lecture seule, ces droits devraient être retirés ou restreints une fois les audits terminés.

Toutes les commandes ont été exécutées uniquement sur le périmètre du laboratoire, conformément au cadre légal rappelé au chapitre 3 (loi n° 2013-451).

Tableau 1 — *Déroulement de l'analyse.*

Étape	Action	Outil / résultat
1	Découverte des hôtes du sous-réseau	Nmap -sn : 4 hôtes actifs
2	Énumération des ports et services TCP/UDP de srv-linux	Nmap -sS -sV -O -p- et -sU (top 50)
3	Détection de vulnérabilités par bannières	Nmap --script vuln (moteur vulners)
4	Scan OpenVAS non authentifié	Tâche « scan OpenVAS non authentifié » (Full and fast)
5	Scan OpenVAS authentifié (SSH, compte auditeur)	Tâche « scan OpenVAS authentifié » (Full and fast)
6	Validation des faux positifs et documentation de trois vulnérabilités	apt changelog, debsecan, CISA KEV

Limites et précautions.

- **Couverture :** OpenVAS n'a scanné qu'un seul actif (srv-linux) sur les 4 hôtes découverts ; R1, SW1 et la machine Kali d'audit ne sont pas couverts.
- **Fiabilité :** les rapports exportés sont filtrés à QoD ≥ 70 ; les détections moins fiables ne sont pas détaillées (voir 4.3). Le statut KEV et les scores CVSS sont relevés à la date du rapport et évoluent.
- **Conditions réelles :** un scan authentifié est plus intrusif. En production, il se ferait dans une fenêtre convenue, en prévenant l'équipe d'exploitation et le SOC.
- **Preuves :** les résultats forment une carte des faiblesses du système ; ils sont conservés avec leurs empreintes SHA-256 (annexes B et C).

3. Découverte réseau et services (Nmap)

Commandes utilisées (exécutées depuis Kali, dossier ~/tp2) :

```
nmap -sn 10.10.20.0/24 -oA decouverte
sudo nmap -sS -sV -O -p- 10.10.20.15 -oA srv_complet
sudo nmap -sU --top-ports 50 10.10.20.15 -oA srv_udp
nmap -sV --script vuln 10.10.20.15 -oA srv_vuln
sha256sum * > empreintes.txt
```

Résultats de la découverte : 4 hôtes actifs détectés sur le sous-réseau (10.10.20.1, .2, .10 et .15).

Tableau 2 — *Hôtes actifs du sous-réseau 10.10.20.0/24 (nmap -sn).*

Adresse	Équipement	Observation Nmap
10.10.20.1	R1 (routeur)	Hôte actif, MAC 50:00:00:01:00:01
10.10.20.2	SW1 (commutateur)	Hôte actif, MAC 50:00:00:02:80:01
10.10.20.10	Kali Linux (machine d'audit)	Hôte actif (machine locale, sans adresse MAC affichée)
10.10.20.15	srv-linux (cible)	Hôte actif, MAC 00:0C:29:BC:43:34 (VMware)

Résultats sur srv-linux (10.10.20.15) :

Tableau 3 — *Services détectés sur srv-linux.*

Port	Service / version	Observation
22/tcp	OpenSSH 8.9p1 (Ubuntu 3ubuntu0.17)	Seul accès d'administration à distance ouvert
80/tcp	Apache httpd 2.4.52 (Ubuntu)	Service web exposé
UDP (top 50)	Aucun port ouvert	Aucune exposition UDP détectée : 20 ports « closed » et 30 « open|filtered » (sans réponse), aucun « open »
Système (-O)	Linux 4.x / 5.x (détection approximative)	Le système réel est confirmé par la connexion SSH : Ubuntu 22.04.5 LTS, noyau 5.15.0-119

```
Nmap scan report for 10.10.20.15
Host is up (0.042s latency).
Not shown: 65533 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 8.9p1 Ubuntu 3ubuntu0.17 (Ubuntu Linux; protocol 2.0)
80/tcp open  http    Apache httpd 2.4.52 ((Ubuntu))
MAC Address: 00:0C:29:BC:43:34 (VMware)
```

Figure 3 — *Extrait de la sortie de « nmap -sS -sV -O -p- 10.10.20.15 » (sortie commentée en annexe A).*

Le script --script vuln (moteur vulners) a remonté une longue liste de CVE par simple correspondance de bannières de version : 121 entrées pour OpenSSH 8.9p1 (dont 26 CVE) et 143 entrées pour Apache 2.4.52 (dont 66 CVE), soit 92 lignes de CVE au total. Ce type de détection ne tient pas compte du rétroportage de correctifs (backport) pratiqué par Ubuntu, ce qui génère un nombre important de faux positifs devant être validés (voir section 5). Les scripts NSE web n'ont trouvé ni XSS ni CSRF sur le port 80.

L'intégrité des 12 fichiers de sortie Nmap (4 scans × formats .nmap, .gnmap et .xml) est attestée par les empreintes SHA-256 de l'annexe B.

4. Scan OpenVAS : non authentifié puis authentifié

4.1 Configuration des cibles, du compte et des tâches

Deux cibles ont été créées dans OpenVAS sur la même adresse IP (10.10.20.15) : une sans identifiants (srv-linux-non-auth) et une avec le compte SSH auditeur associé (srv-linux-auth). Les deux utilisent la liste de ports « All IANA assigned TCP ».

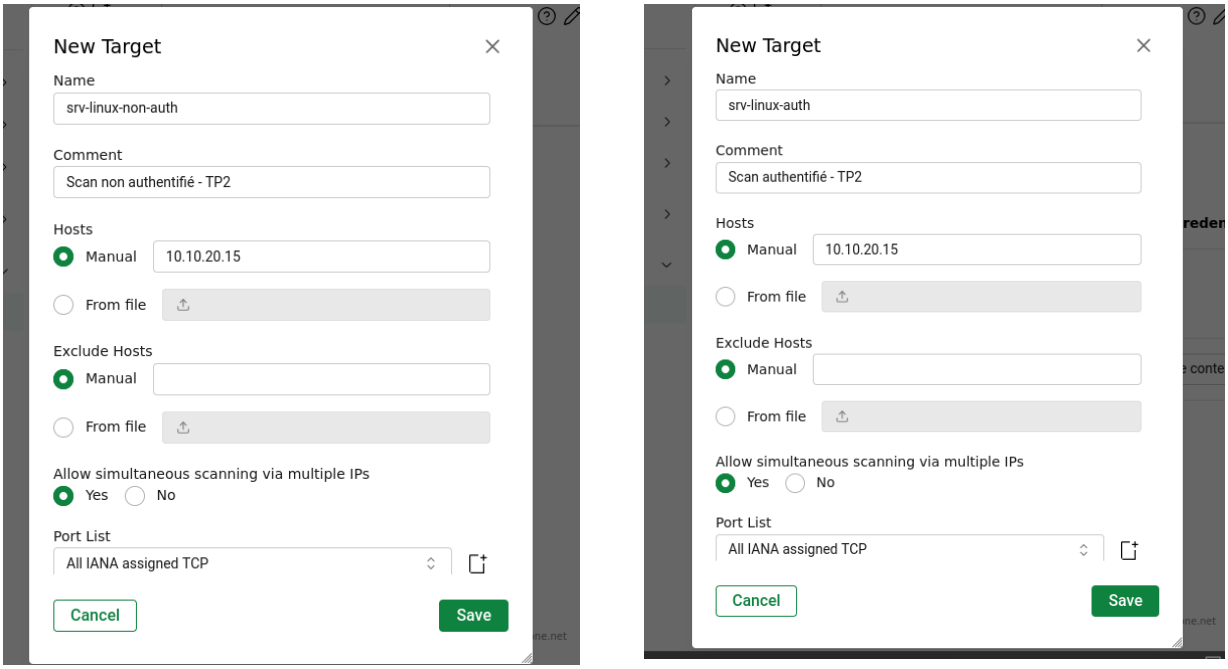


Figure 4 — *Création des cibles OpenVAS : (a) srv-linux-non-auth ; (b) srv-linux-auth. Hôte 10.10.20.15 dans les deux cas.*

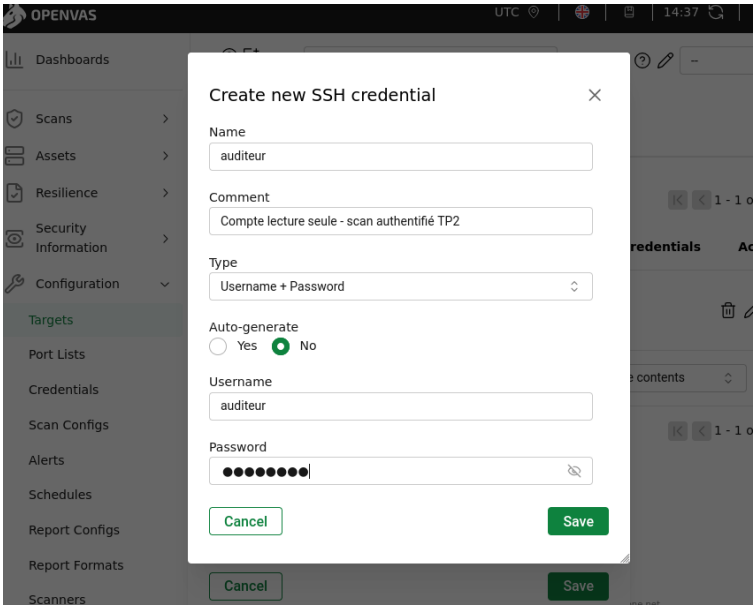


Figure 5 — *Identifiant SSH « auditeur » (Username + Password) créé pour le scan authentifié ; le mot de passe est masqué.*

Deux tâches ont été lancées avec la configuration de scan « Full and fast » (scanner OpenVAS Default, 4 NVT simultanés par hôte, 20 hôtes simultanés) : « scan OpenVAS non authentifié » sur la cible srv-linux-non-auth, puis « scan OpenVAS authentifié » sur la cible srv-linux-auth.

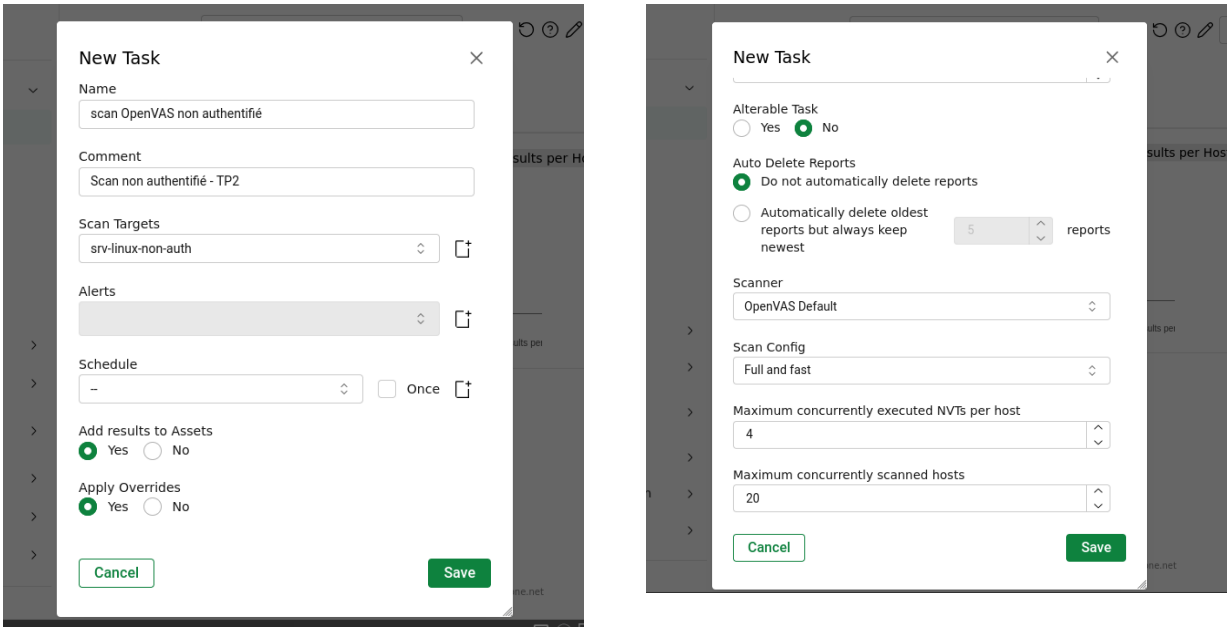


Figure 6 — *Création de la tâche non authentifiée : (a) nom, cible et options ; (b) scanner OpenVAS Default et configuration « Full and fast ».*

Le scan non authentifié s'est déroulé le 24/09/2026 de 14:50 à 15:08 (UTC), puis le scan authentifié de 15:09 à 15:29 (UTC). Les deux tâches sont terminées (« Done ») avec un rapport chacune (figure 7).

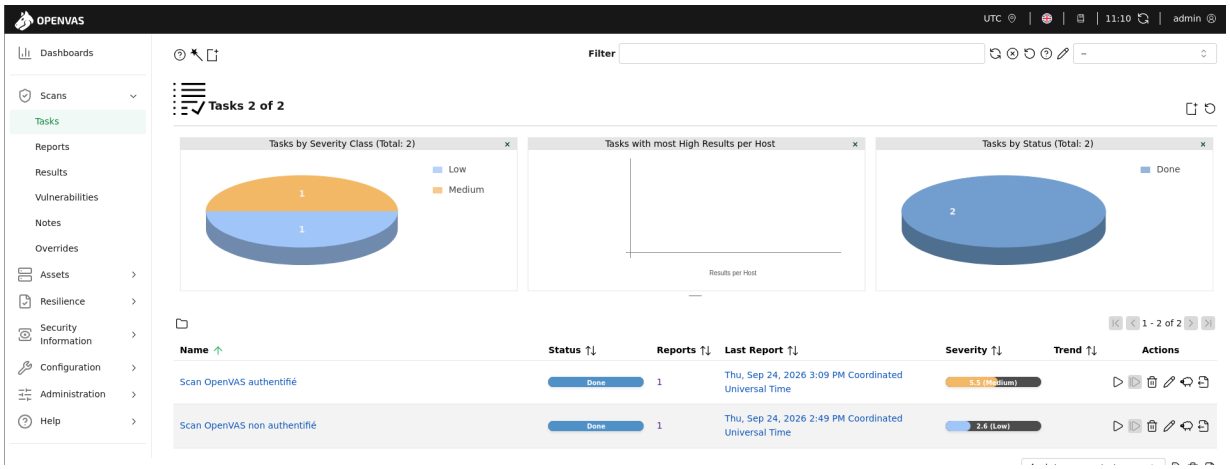


Figure 7 — *Liste des tâches OpenVAS : scan non authentifié (2.6, Low) et scan authentifié (5.5, Medium).*

4.2 Comparaison des deux scans

Le rapport du scan authentifié confirme que l'authentification SSH a réussi (port 22, utilisateur auditeur), condition indispensable pour que ses résultats soient exploitables : la mention Auth-SSH-Success figure dans le rapport XML (annexe C.3). Les rapports complets sont conservés au format XML comme preuves.

Tableau 4 — *Comparaison des scans non authentifié et authentifié (cible et configuration identiques).*

Critère	Scan non authentifié	Scan authentifié
Période (UTC)	24/09/2026, 14:50:15 à 15:08:14	24/09/2026, 15:09:45 à 15:29:20
Durée du scan	Environ 18 min (scan de l'hôte : 17 min)	Environ 20 min (scan de l'hôte : 19 min)
Authentification	Aucune	SSH réussie (port 22, utilisateur auditeur)
Résultats avant filtrage	51	232
Répartition brute (avant filtre QoD)	7 critiques, 5 élevés, 16 moyens, 6 faibles, 17 logs	23 critiques, 56 élevés, 101 moyens, 12 faibles, 40 logs
Résultats retenus (QoD ≥ 70)	3	5
Répartition par sévérité (retenus)	0 critique, 0 élevé, 0 moyen, 3 faible	0 critique, 0 élevé, 1 moyen, 4 faible
Sévérité maximale	2.6 (Low)	5.5 (Medium)
Fiabilité	Vision limitée à ce qui est visible depuis le réseau, sans lecture des paquets installés ni de l'état du noyau	Vision précise : lecture des versions réellement installées et de l'état du noyau via SSH

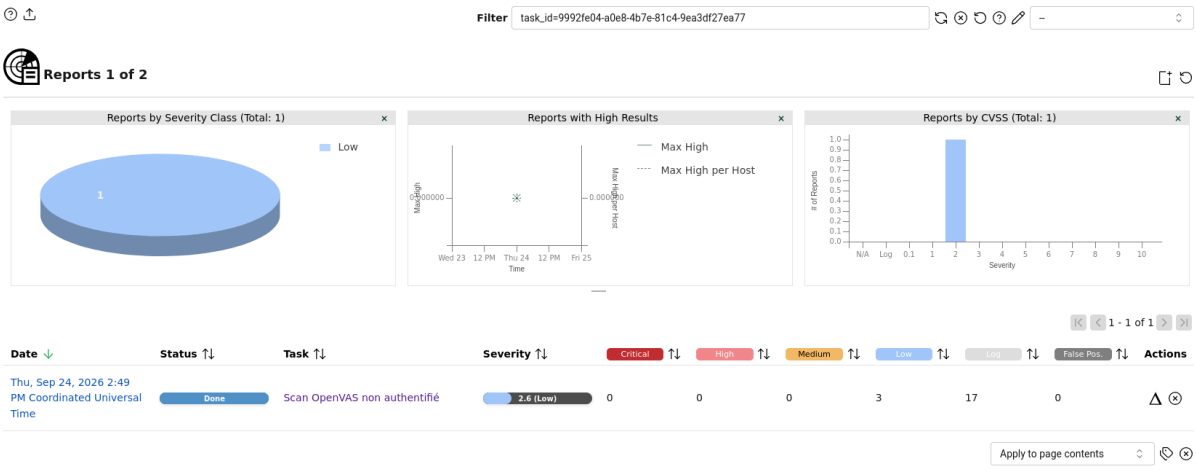


Figure 8 — *Rapport du scan non authentifié : 0 critique, 0 élevé, 0 moyen, 3 faible, 17 log ; sévérité 2.6 (Low).*

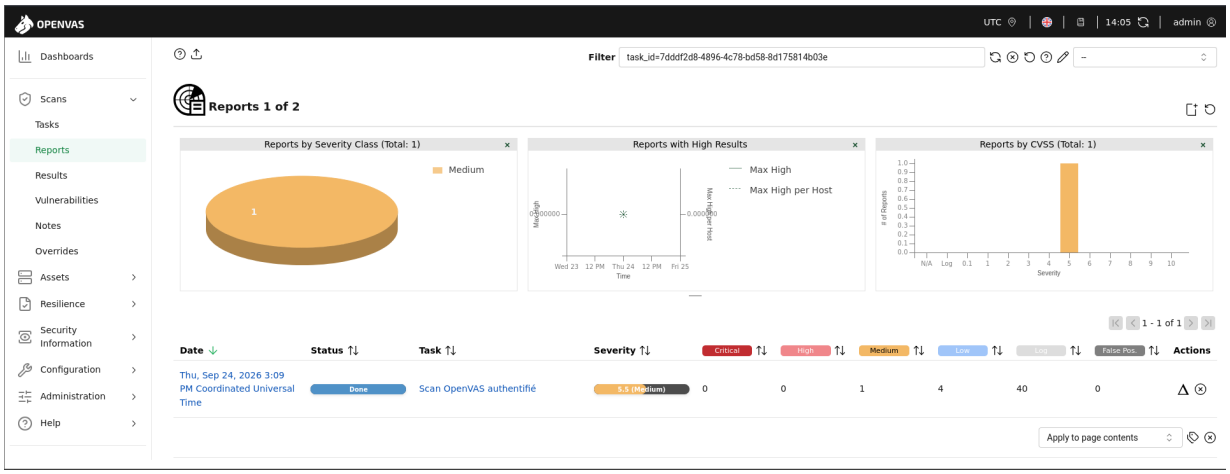


Figure 9 — *Rapport du scan authentifié : 0 critique, 0 élevé, 1 moyen, 4 faible, 40 log ; sévérité 5.5 (Medium).*

Les rapports ont été exportés au format « Anonymous XML » avec le filtre min_qod=70 (figure 10).

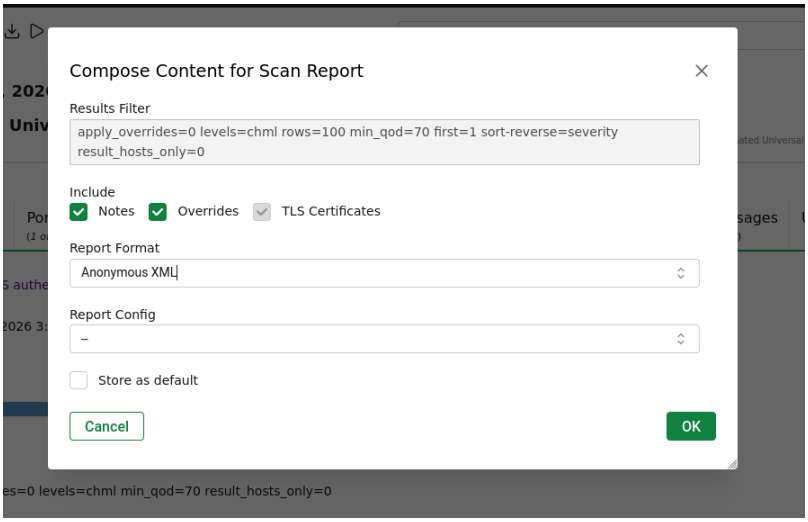


Figure 10 — *Export du rapport : filtre min_qod=70, notes et overrides inclus, format Anonymous XML.*

> **Lecture des fichiers XML.** Ce format remplace l'adresse de l'hôte par 127.0.0.1 dans tout le fichier, et le libellé de cible qui y figure (« TP2 - cible non auth » et « TP2 - cible auth ») diffère du nom saisi à la création (srv-linux-non-auth, srv-linux-auth). Le rapprochement avec les captures est assuré par les identifiants de tâche (9992fe04-a0e8-4b7e-81c4-9ea3df27ea77 et 7dddf2d8-4896-4c78-bd58-8d175814b03e), par les horaires de scan et par les services détectés (Ubuntu 22.04, OpenSSH 8.9p1, Apache 2.4.52, ports 22 et 80), qui sont ceux de srv-linux.

4.3 Résultats remontés par OpenVAS

Aucun résultat critique ou élevé n'a été retenu, ni par le scan non authentifié, ni par le scan authentifié. Le tableau ci-dessous compare les constats retenus (QoD ≥ 70, ici 80 % pour les cinq constats) :

Tableau 5 — *Constats retenus par OpenVAS (QoD ≥ 70).*

Constat OpenVAS	Sévérité (CVSS)	CVE	Non authentifié	Authentifié
Missing Linux Kernel mitigations for 'VMScape' hardware vulnerability	Moyenne (5.5)	CVE-2025-40300	Non détecté	Détecté
Missing Linux Kernel mitigations for 'TSA' hardware vulnerabilities (AMD-SB-7029)	Faible (3.8)	CVE-2024-36348, CVE-2024-36349, CVE-2024-36350, CVE-2024-36357	Non détecté	Détecté
Weak MAC Algorithm(s) Supported (SSH), port 22/tcp	Faible (2.6)	Aucun	Détecté	Détecté
TCP Timestamps Information Disclosure	Faible (2.6)	Aucun	Détecté	Détecté
ICMP Timestamp Reply Information Disclosure	Faible (2.1)	CVE-1999-0524	Détecté	Détecté

Les 51 et 232 résultats bruts comprennent aussi des détections de faible fiabilité (QoD inférieure à 70) que le filtre standard écarte ; c'est le cas des 12 résultats critiques ou élevés du scan non authentifié et des 79 du scan authentifié. L'export XML fourni ne contient que les résultats filtrés : ces détections ne sont donc pas détaillées dans ce rapport, et leur validation est traitée par la vérification des correctifs en section 5.

4.4 Analyse et interprétation

Constats communs aux deux scans (3). Les faiblesses des algorithmes MAC SSH (selon OpenVAS : algorithmes à base de MD5, de 96 bits ou de 64 bits ; sur OpenSSH 8.9, il s'agit des variantes umac-64 et umac-64-etm), des horodatages TCP et des horodatages ICMP sont visibles depuis le réseau : elles sont donc remontées à l'identique par les deux scans. Ce sont des constats de durcissement à faible risque. Mesures correctives : retirer les MAC umac-64 de la directive MACs de /etc/ssh/sshd_config puis redémarrer le service ssh ; ajouter net.ipv4.tcp_timestamps = 0 dans /etc/sysctl.conf puis exécuter sysctl -p (gain de sécurité marginal, à arbitrer selon l'impact sur les performances réseau) ; filtrer les messages ICMP timestamp-request et timestamp-reply au niveau du pare-feu de l'hôte.

Constats propres au scan authentifié (2). Les alertes VMScape (CVSS 5.5, seul constat de sévérité moyenne) et TSA (CVSS 3.8) portent sur les mitigations matérielles du noyau Linux. OpenVAS les détecte en exploitant, par SSH, l'état des mitigations rapporté par le noyau (fichiers /sys/devices/system/cpu/vulnerabilities/vmscape et /sys/devices/system/cpu/vulnerabilities/tsa) : lorsque le noyau installé ne connaît pas encore ces vulnérabilités, ces fichiers sont absents et OpenVAS suppose l'absence de mitigation (QoD de 80 %). Le noyau de srv-linux est un 5.15.0-119-generic (figure 2), ancien au regard de ces vulnérabilités récentes. Cette information est interne au système et n'est pas accessible sans authentification, ce qui explique qu'elle n'apparaisse pas dans le

scan non authentifié. Ces résultats restent à qualifier : TSA ne concerne que certains processeurs AMD, et VMScape concerne surtout les hyperviseurs (par exemple QEMU) ; l'exposition réelle dépend donc du processeur de srv-linux et de son rôle. Vérifications proposées : uname -r et lscpu pour le noyau et le CPU, puis contrôle des mises à jour de noyau et de microcode. Mesure corrective : mettre à jour le noyau (sudo apt update && sudo apt upgrade) et le microcode (paquets intel-microcode ou amd64-microcode), puis redémarrer. Si le processeur n'est pas concerné, créer un override dans OpenVAS pour ne pas fausser le suivi.

Cohérence avec la section 5. Ni CVE-2024-6387 (OpenSSH) ni CVE-2022-31813 (Apache) n'apparaissent parmi les résultats retenus du scan authentifié, alors que la correspondance de bannières de Nmap les signalait. Cela est cohérent avec le rétroportage des correctifs confirmés par apt changelog : ce sont bien des faux positifs de détection par bannières. À l'inverse, CVE-2025-32462 (sudo), vrai positif confirmé, n'apparaît pas non plus dans les résultats retenus par OpenVAS (filtre QoD ≥ 70) : il a été identifié grâce à debsecan. Un scanner, même authentifié, ne couvre donc pas tout : il faut croiser les sources (OpenVAS, Nmap, debsecan, changelogs) avant de conclure.

Bilan de la comparaison : à cible et configuration identiques, le scan authentifié a produit 232 résultats bruts contre 51 pour le scan non authentifié, pour une durée comparable (environ 20 contre 18 minutes). Il est le seul à révéler l'état interne du système (mitigations du noyau) et le seul à donner une image fiable des correctifs installés, ce qui confirme les limites d'un scan non authentifié fondé sur les bannières (chapitre 3, tableaux 7 et 13). Son coût est la nécessité de disposer d'un compte dédié (ici le compte SSH auditeur) et une intrusivité plus grande.

5. Les trois vulnérabilités documentées

5.1 CVE-2024-6387 (regreSSHion) — OpenSSH

Champ	Détail
Description	Condition de course dans sshd pouvant permettre une exécution de code à distance avant authentification.
CVSS	8.1
CISA KEV	Oui, ajoutée au catalogue le 25 février 2026 (vulnérabilité activement exploitée).
Origine de la détection	Correspondance de bannière Nmap / OpenVAS sur la version « OpenSSH 8.9p1 », qui se situe dans la plage vulnérable annoncée (8.5p1 à 9.7p1). Nmap la liste avec le score 8.1 (annexe A) ; OpenVAS identifie la même version (cpe:/a:openbsd:openssh:8.9p1, annexe C).
Vérification complémentaire	apt changelog openssh-server confirme la présence du correctif CVE-2024-6387.patch (appliqué le 26/06/2024), inclus dans la version installée 1:8.9p1-3ubuntu0.17.
Faux positif ?	Oui. Le correctif est rétroporté par Ubuntu ; le numéro de version affiché ne change pas mais la vulnérabilité est corrigée.
Risque réel	Nul. Aucune action requise.
Mesure corrective	Aucune. À noter dans le rapport comme faux positif vérifié, pour éviter un traitement inutile.

5.2 CVE-2022-31813 — Apache httpd (mod_proxy)

Champ	Détail
Description	mod_proxy ne transmet pas correctement les en-têtes X-Forwarded-*, ce qui peut permettre un contournement de restrictions basées sur l'adresse IP source.
CVSS	9.8 (critique)
CISA KEV	Non recensée au catalogue KEV à ce jour.
Origine de la détection	Correspondance de bannière sur « Apache httpd 2.4.52 », version annoncée comme vulnérable (corrigé en 2.4.54). Nmap la liste avec le score 9.8 (annexe A) ; OpenVAS identifie la même version (cpe:/a:apache:http_server:2.4.52, annexe C).
Vérification complémentaire	apt changelog apache2 confirme le correctif CVE-2022-31813.patch appliqué le 14/06/2022, inclus dans la version installée 2.4.52-1ubuntu4.23.
Faux positif ?	Oui, même mécanisme de rétroportage que pour OpenSSH.
Risque réel	Nul.
Mesure corrective	Aucune. Constat à documenter comme faux positif afin d'éviter de fausser le taux de conformité global du rapport.

5.3 CVE-2025-32462 — sudo (option --host)

Champ	Détail
Description	L'option -h / --host de sudo, normalement réservée à la liste des privilèges (-l), peut être utilisée pour exécuter une commande. Si le fichier sudoers restreint des règles à un hôte précis (différent de ALL), un utilisateur local peut ainsi obtenir les privilèges prévus pour une autre machine.
CVSS	8.8 (CVSS 3.1, NVD, vecteur AV:L/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H). Le score varie selon la source : Ubuntu évalue un vecteur nettement plus faible (AV:L/AC:H, impact limité), ce qui illustre les limites d'un score brut.
CISA KEV	Non recensée au catalogue KEV à ce jour.
Origine de la détection	Identifiée via debsecan sur srv-linux, qui liste sudo parmi les paquets porteurs de CVE non corrigées. L'inventaire du scan authentifié recense d'ailleurs sudo 1.9.9 (cpe:/a:sudo_project:sudo:1.9.9).
Vérification complémentaire	Version installée : sudo 1.9.9-1ubuntu2.4. Le correctif CVE-2025-32462 n'apparaît dans le changelog Ubuntu qu'à partir de la version 1.9.9-1ubuntu2.5 (25/06/2025). La version installée est donc antérieure au correctif.
Faux positif ?	Non. Vrai positif confirmé.
Risque réel	Exige un accès local préalable (compte utilisateur sur la machine) : ce n'est pas exploitable directement depuis le réseau. Le risque dépend de la configuration du fichier /etc/sudoers : il n'est réellement exploitable que si des règles y restreignent des privilèges à un hôte différent de ALL. À vérifier sur srv-linux avant de qualifier définitivement la sévérité opérationnelle.
Mesure corrective	Mettre à jour le paquet sudo vers une version intégrant le correctif (sudo apt install sudo, ou sudo apt upgrade sudo), soit au moins la 1.9.9-1ubuntu2.5 ou une version ultérieure.

Tableau 6 — *Synthèse des trois vulnérabilités documentées.*

Vulnérabilité	CVSS	CISA KEV	Nature	Risque réel	Action
CVE-2024-6387 (OpenSSH)	8.1	Oui	Faux positif (backport)	Nul	Aucune
CVE-2022-31813 (Apache)	9.8	Non	Faux positif (backport)	Nul	Aucune
CVE-2025-32462 (sudo)	8.8	Non	Vrai positif	Modéré (accès local)	Mettre à jour sudo

Priorisation et qualification. Le score CVSS seul ne suffit pas : la priorité combine la sévérité, l'exploitabilité réelle (catalogue KEV), l'exposition et la criticité de l'actif (paragraphe 3.8 du cours). Chaque vulnérabilité est ensuite qualifiée C, PC ou NC au titre de la mesure B.10.13 du RGSSI (gestion des vulnérabilités techniques).

Tableau 7 — *Priorisation selon les quatre facteurs et qualification.*

Vulnérabilité	Sévérité (CVSS)	Exploitabilité (KEV)	Exposition	Priorité / qualification
CVE-2024-6387 (OpenSSH)	8.1, élevé	Oui, mais corrigée	Port 22 joignable sur le réseau	Aucune · C (correctif installé)
CVE-2022-31813 (Apache)	9.8, critique	Non	Port 80 joignable sur le réseau	Aucune · C (correctif installé)
CVE-2025-32462 (sudo)	8.8, élevé	Non	Locale uniquement	Priorité 1 · PC (paquet non à jour)

La criticité de l'actif n'est pas établie (srv-linux est un serveur de laboratoire) ; elle serait à pondérer en production. L'EPSS n'a pas été consulté. La qualification C / PC est proposée par les auteurs selon la grille du chapitre 2.

Tableau 8 — *Causes d'erreur rencontrées et parades appliquées.*

Cause d'erreur	Effet observé	Parade appliquée
Détection par bannière de version	Faux positifs : CVE-2024-6387 et CVE-2022-31813 signalées alors que le correctif est rétroporté.	Vérification du paquet installé avec apt changelog.
Scan non authentifié	Failles locales invisibles : VMScape et TSA n'apparaissent qu'en scan authentifié.	Scan authentifié avec le compte SSH auditeur.
Filtre QoD ≥ 70	CVE-2025-32462 (vrai positif) absente des résultats OpenVAS retenus : un faux négatif.	Recoupement avec debsecan sur la cible.

6. Synthèse

Les trois vulnérabilités choisies illustrent bien la démarche d'interprétation présentée au chapitre 3 (section 5) : deux constats à fort score CVSS affiché (8.1 et 9.8) se révèlent en réalité corrigés par rétroportage, tandis que la troisième (sudo, CVSS 8.8) est un vrai positif. Son risque opérationnel reste toutefois modéré : il exige un accès local préalable et une configuration sudoers particulière, ce qui montre que le score CVSS ne suffit pas à lui seul à hiérarchiser.

Cela confirme qu'un score CVSS brut, ou une simple correspondance de bannière de version, ne suffit jamais à conclure sur la réalité d'un risque. Seule la vérification directe des correctifs effectivement installés (via un scan authentifié ou, à défaut, la consultation des changelogs du système) permet de distinguer un vrai positif d'un faux positif.

La comparaison des deux scans OpenVAS confirme l'apport de l'authentification : 51 résultats bruts et 3 retenus (tous de sévérité faible) sans identifiants, 232 et 5 avec identifiants, dont un constat de sévérité moyenne (mitigations noyau VMScape) invisible depuis le réseau. Aucun scan n'a remonté de résultat critique ou élevé au seuil QoD ≥ 70. Les constats communs (algorithmes MAC SSH faibles, horodatages TCP et ICMP) sont des mesures de durcissement à faible risque.

Lire correctement les scores. La sévérité 2.6 (Low) du scan non authentifié et la sévérité 5.5 (Medium) du scan authentifié sont des indicateurs de tendance, pas des preuves de sécurité (paragraphe 5.4 du cours) : le « faible » du premier traduit la vision limitée du scanner et non l'absence de risque. Les constats doivent être examinés un par un ; c'est l'évolution entre deux scans, avant et après correction, qui sera la plus parlante.

Corrélation avec le TP 1. L'audit Lynis du 23/09/2026 avait signalé un paquet vulnérable (PKGS-7392, avec 193 mises à jour de sécurité en attente) et l'absence de règle de pare-feu (FIRE-4512). Ces deux constats sont cohérents avec le présent TP : le paquet vulnérable est probablement sudo (CVE-2025-32462), ce que Lynis ne permet pas de confirmer puisqu'il ne nomme pas le paquet ; les mises à jour en attente appuient la mise à jour du noyau ; sans pare-feu, rien ne limite l'accès aux ports 22 et 80 depuis le réseau local.

Recommandations, par ordre de priorité :

- (1) mettre à jour le paquet sudo (CVE-2025-32462) et vérifier le fichier /etc/sudoers ;
- (2) mettre à jour le noyau et le microcode, en qualifiant d'abord l'exposition réelle aux alertes VMScape et TSA ;
- (3) durcir la configuration SSH et réseau (MAC umac-64, horodatages TCP et ICMP) ;
- (4) documenter les deux constats OpenSSH et Apache comme faux positifs vérifiés dans le registre de suivi, afin de ne pas fausser le taux de conformité global calculé pour le tableau de bord d'audit.

Plan d'actions et indicateurs de suivi. Les indicateurs reprennent ceux du tableau 12 du cours.

Tableau 9 — *Plan d'actions proposé.*

Action	Priorité	Indicateur de suivi
Mettre à jour sudo et contrôler /etc/sudoers	Haute	Version sudo ≥ 1.9.9-1ubuntu2.5 ; nouveau scan authentifié
Qualifier VMScape (5.5) et TSA (3.8), puis mettre à jour noyau et microcode	Moyenne	Constats clos, ou override OpenVAS justifié
Durcir SSH (MAC umac-64), horodatages TCP et ICMP	Basse	Constats absents du nouveau scan
Consigner les deux faux positifs dans le registre de suivi	Moyenne	Taux de conformité non faussé
Étendre la couverture des scans aux autres actifs	Basse	Couverture des scans : 1 actif sur 4 aujourd'hui

L'avancement du plan se mesure par le ratio actions clôturées sur actions planifiées, soit 0 sur 5 à la date de ce rapport.

Annexe A — Sortie Nmap (extrait)

Extrait du fichier « Nmap (découverte et services), dans le laboratoire.txt » : les quatre commandes, la découverte, le scan complet, le scan UDP et le scan --script vuln. Dans ce dernier, seules les premières entrées de chaque liste vulners et les lignes CVE-2024-6387 et CVE-2022-31813 sont conservées ; les lignes omises sont signalées par « [... n lignes omises ...] ».

```
┌──(n0xsidik㉿null)-[~]
└─$ mkdir -p ~/tp2 && cd ~/tp2
nmap -sn 10.10.20.0/24 -oA decouverte
sudo nmap -sS -sV -O -p- 10.10.20.15 -oA srv_complet
sudo nmap -sU --top-ports 50 10.10.20.15 -oA srv_udp
nmap -sV --script vuln 10.10.20.15 -oA srv_vuln
sha256sum * > empreintes.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-24 00:53 +0000
Nmap scan report for 10.10.20.1
Host is up (0.0044s latency).
MAC Address: 50:00:00:01:00:01 (Unknown)
Nmap scan report for 10.10.20.2
Host is up (0.023s latency).
MAC Address: 50:00:00:02:80:01 (Unknown)
Nmap scan report for 10.10.20.15
Host is up (0.0088s latency).
MAC Address: 00:0C:29:BC:43:34 (VMware)
Nmap scan report for 10.10.20.10
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 5.51 seconds
[sudo] Mot de passe de n0xsidik :
Désolé, essayez de nouveau.
[sudo] Mot de passe de n0xsidik :
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-24 00:53 +0000
Nmap scan report for 10.10.20.15
Host is up (0.042s latency).
Not shown: 65533 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 8.9p1 Ubuntu 3ubuntu0.17 (Ubuntu Linux; protocol 2.0)
80/tcp open  http    Apache httpd 2.4.52 ((Ubuntu))
MAC Address: 00:0C:29:BC:43:34 (VMware)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7
cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux
5.6.3)
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 68.45 seconds
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-24 00:54 +0000
Nmap scan report for 10.10.20.15
Host is up (0.0062s latency).
Not shown: 30 open|filtered udp ports (no-response)
PORT     STATE  SERVICE
```

```
69/udp    closed tftp
80/udp    closed http
136/udp   closed profile
137/udp   closed netbios-ns
139/udp   closed netbios-ssn
162/udp   closed snmptrap
445/udp   closed microsoft-ds
500/udp   closed isakmp
631/udp   closed ipp
997/udp   closed maitrd
1025/udp  closed blackjack
1026/udp  closed win-rpc
1433/udp  closed ms-sql-s
1701/udp  closed L2TP
2049/udp  closed nfs
3456/udp  closed IISrpc-or-vat
4500/udp  closed nat-t-ike
5060/udp  closed sip
5353/udp  closed zeroconf
49152/udp closed unknown
MAC Address: 00:0C:29:BC:43:34 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 15.68 seconds
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-24 00:55 +0000
Nmap scan report for 10.10.20.15
Host is up (0.076s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 8.9p1 Ubuntu 3ubuntu0.17 (Ubuntu Linux; protocol 2.0)
| vulners:
|   cpe:/a:openbsd:openssh:8.9p1:
|       PACKETSTORM:179290      10.0
https://vulners.com/packetstorm/PACKETSTORM:179290      *EXPLOIT*
|       1EEC8894-D2F7-547C-827C-915BE866875C    10.0
https://vulners.com/githubexploit/1EEC8894-D2F7-547C-827C-915BE866875C      *EXPLOIT*
|       09B905C6-CD97-54E6-AD97-B0DD1AC4771B    10.0
https://vulners.com/githubexploit/09B905C6-CD97-54E6-AD97-B0DD1AC4771B
*EXPLOIT*
|       PACKETSTORM:173661      9.8
https://vulners.com/packetstorm/PACKETSTORM:173661      *EXPLOIT*
|       F0979183-AE88-53B4-86CF-3AF0523F3807    9.8
https://vulners.com/githubexploit/F0979183-AE88-53B4-86CF-3AF0523F3807      *EXPLOIT*
|       CVE-2023-38408  9.8     https://vulners.com/cve/CVE-2023-38408
|       [... 31 lignes omises ...]
|       CVE-2024-6387   8.1     https://vulners.com/cve/CVE-2024-6387
|       [... 83 lignes omises ...]
80/tcp open  http    Apache httpd 2.4.52 ((Ubuntu))
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-server-header: Apache/2.4.52 (Ubuntu)
| vulners:
|   cpe:/a:apache:http_server:2.4.52:
|       PACKETSTORM:176334      9.8
https://vulners.com/packetstorm/PACKETSTORM:176334      *EXPLOIT*
```

```
|       HTTPD:C072933AA965A86DA3E2C9172FFC1569  9.8
https://vulners.com/httpd/HTTPD:C072933AA965A86DA3E2C9172FFC1569
|       HTTPD:A09F9CEBE0B7C39EDA0480FEAEF4FE9D  9.8
https://vulners.com/httpd/HTTPD:A09F9CEBE0B7C39EDA0480FEAEF4FE9D
|       HTTPD:2BE0032A6ABE7CC52906DBAAFE0E448E  9.8
https://vulners.com/httpd/HTTPD:2BE0032A6ABE7CC52906DBAAFE0E448E
|       D5084D51-C8DF-5CBA-BC26-ACF2E33F8E52    9.8
https://vulners.com/githubexploit/D5084D51-C8DF-5CBA-BC26-ACF2E33F8E52
*EXPLOIT*
|       CVE-2024-38476  9.8     https://vulners.com/cve/CVE-2024-38476
|       [... 2 lignes omises ...]
|       CVE-2022-31813  9.8     https://vulners.com/cve/CVE-2022-31813
|       [... 134 lignes omises ...]
MAC Address: 00:0C:29:BC:43:34 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 44.31 seconds


┌──(n0xsidik㉿null)-[~/tp2]
└─$
```

Annexe B — Empreintes SHA-256 des sorties Nmap

Contenu du fichier « empreintes.txt », produit par sha256sum * > empreintes.txt dans le dossier ~/tp2 après les quatre scans.

Fichier	SHA-256
decouverte.gnmap	414e1df210fcd8ce8e54765fc012030cf417b1d6a0d8821dcb7e7b6ac5b16205
decouverte.nmap	05cc7f3bee2b0bf257ebce03175057799a86e08b746524046b625609dbbdcbfa
decouverte.xml	e5052298dab87a5b0d990275a8b9572b7416dd07f74d1e91e3424d4decab4315
srv_complet.gnmap	50f8326059cb9c746a0a6c6537b4bfd1900e77456d848996fbd50d855086b3ec
srv_complet.nmap	d44321f4baf12032f62fff3c0609f30a39e1e53ad8def29d36b8a5e6b437b8c9
srv_complet.xml	e7a22cd82d640efe8f786d9aa28085e8b9a124970193a060be07e184e874fe72
srv_udp.gnmap	e4faccd2046b52a562b4ea26a830853e1505ecad40b3696c6c2d858dd8c7bba6
srv_udp.nmap	6360cebd1e5809b9997125a921008c270b7102c11fc4f76997a188ade5b44de6
srv_udp.xml	58fcf3eff7198ddfff9e5bee36e5e7f80f8a147c3bc2cd29aac49640a2875638
srv_vuln.gnmap	24a9a3af33399372dd3b95100a97a69fad3de9aba7d7013bada952d063ab9191
srv_vuln.nmap	08b258ad72d7aa61d8ff3d89a68e15d95ad566cb9932552303746eb5dbf5e2f4
srv_vuln.xml	12d4061cfff0ab12e26b1c7926913c33c4adfa9156bb9072f67addfc3475f445

Annexe C — Rapports OpenVAS au format XML

C.1 Fichiers fournis

Fichier	Taille (octets)	Période du scan (UTC)	SHA-256
report-Scan OpenVAS non authentifié.xml	313 393	24/09/2026 14:50:15 → 15:08:14	d8fc1f6fc79c357f6938545425947 67defe1952013d59bde2e98222b5 ccaa819
report-Scan OpenVAS authentifié.xml	391 537	24/09/2026 15:09:45 → 15:29:20	a05a25c167263eb7c6651425f7ece df010436062fd2f5a32cb6f0e60c1 f7b578

Les fichiers XML complets sont livrés avec ce rapport, sans modification. Les extraits ci-dessous en reproduisent les éléments utiles : en-tête du rapport (identifiants, horaires, décompte des résultats, filtre), hôte et résultats retenus (QoD ≥ 70). Les blancs sont normalisés pour la lecture.

C.2 Scan non authentifié (3 résultats retenus)

```
<!-- Extrait de : report-Scan OpenVAS non authentifié.xml (format Anonymous XML, filtre min_qod=70) -->
<report id="532b5dc3-44a3-4a71-87b4-16de1ea59a0a">
  <creation_time>2026-09-24T14:49:59Z</creation_time>
  <report>
    <scan_run_status>Done</scan_run_status>
    <timestamp>2026-09-24T14:49:59Z</timestamp>
    <scan_start>2026-09-24T14:50:15Z</scan_start>
    <scan_end>2026-09-24T15:08:14Z</scan_end>
    <timezone_abbrev>UTC</timezone_abbrev>
    <task id="9992fe04-a0e8-4b7e-81c4-9ea3df27ea77">
      <comment />
      <target id="36a6dcc5-d598-4d49-9713-e042a6e00683">
        <trash>0</trash>
        <name>TP2 - cible non auth</name>
        <comment />
      </target>
      <progress>100</progress>
    </task>
    <result_count>51<full>51</full>
      <filtered>3</filtered>
      <critical>
        <full>7</full>
        <filtered>0</filtered>
      </critical>
      <hole deprecated="1">
        <full>5</full>
        <filtered>0</filtered>
      </hole>
      <high>
        <full>5</full>
        <filtered>0</filtered>
      </high>
```

```
      <info deprecated="1">
        <full>6</full>
        <filtered>3</filtered>
      </info>
      <low>
        <full>6</full>
        <filtered>3</filtered>
      </low>
      <log>
        <full>17</full>
        <filtered>0</filtered>
      </log>
      <warning deprecated="1">
        <full>16</full>
        <filtered>0</filtered>
      </warning>
      <medium>
        <full>16</full>
        <filtered>0</filtered>
      </medium>
      <false_positive>
        <full>0</full>
        <filtered>0</filtered>
      </false_positive>
    </result_count>
    <filters><term>apply_overrides=0 levels=chml rows=1000 min_qod=70 first=1 sort-
reverse=severity result_hosts_only=0 notes=1 overrides=1</term></filters>
    <host>
      <ip>127.0.0.1</ip>
      <start>2026-09-24T14:51:02Z</start>
      <end>2026-09-24T15:08:07Z</end>
      <detail>
        <name>ports</name>
        <value>22,80</value>
        <source>
          <type>nvt</type>
          <name>1.3.6.1.4.1.25623.1.0.900239</name>
          <description>Check Open TCP Ports</description>
        </source>
        <extra />
      </detail>
      <detail>
        <name>best_os_txt</name>
        <value>Ubuntu 22.04</value>
        <source>
          <type>nvt</type>
          <name>1.3.6.1.4.1.25623.1.0.105586;</name>
          <description>Operating System (OS) Detection (SSH Banner)</description>
        </source>
        <extra />
      </detail>
    </host>
    <results max="1000" start="1">
      <result id="d6d3c738-b4ea-4660-8c16-fa27410d8c18">
        <name>TCP Timestamps Information Disclosure</name>
        <modification_time>2026-09-24T14:52:56Z</modification_time>
```

```
      <comment />
      <creation_time>2026-09-24T14:52:56Z</creation_time>
      <host>127.0.0.1<asset asset_id="a28c1a16-3ae8-405b-a0d5-d3851cffa5c1" />
        <hostname />
      </host>
      <port>general/tcp</port>
      <nvt oid="1.3.6.1.4.1.25623.1.0.80091">
        <type>nvt</type>
        <name>TCP Timestamps Information Disclosure</name>
        <family>General</family>
        <cvss_base>2.6</cvss_base>
        <severities score="2.6">
          <severity type="cvss_base_v2">
            <origin />
            <date>2008-10-24T21:33:44Z</date>
            <score>2.6</score>
            <value>AV:N/AC:H/Au:N/C:P/I:N/A:N</value>
          </severity>
        </severities>
        <tags>cvss_base_vector=AV:N/AC:H/Au:N/C:P/I:N/A:N|summary=The remote host
implements TCP timestamps and therefore allows to compute the uptime.|insight=The remote host
implements TCP timestamps, as defined by RFC1323/RFC7323.|affected=TCP implementations
that implement RFC1323/RFC7323.|impact=A side effect of this feature is that the uptime of the
remote host can sometimes be computed.|solution=To disable TCP timestamps on linux add the
line 'net.ipv4.tcp_timestamps = 0' to /etc/sysctl.conf. Execute 'sysctl -p' to apply the settings at
runtime. To disable TCP timestamps on Windows execute 'netsh int tcp set global
timestamps=disabled' Starting with Windows Server 2008 and Vista, the timestamp can not be
completely disabled. The default behavior of the TCP/IP stack on this Systems is to not use the
Timestamp options when initiating TCP connections, but use them if the TCP peer that is
initiating communication includes them in their synchronize (SYN) segment. See the references
for more information.|vuldetect=Special IP packets are forged and sent with a little delay in
between to the target IP. The responses are searched for a timestamps. If found, the timestamps are
reported.|solution_type=Mitigation</tags>
        <solution type="Mitigation">To disable TCP timestamps on linux add the line
'net.ipv4.tcp_timestamps = 0' to /etc/sysctl.conf. Execute 'sysctl -p' to apply the settings at runtime.
To disable TCP timestamps on Windows, execute 'netsh int tcp set global timestamps=disabled'
Starting with Windows Server 2008 and Vista, the timestamp can not be completely disabled. The
default behavior of the TCP/IP stack on this Systems is to not use the Timestamp options when
initiating TCP connections, but use them if the TCP peer that is initiating communication includes
them in their synchronize (SYN) segment. See the references for more information.</solution>
        <refs>
          <ref type="url" id="https://datatracker.ietf.org/doc/html/rfc1323" />
          <ref type="url" id="https://datatracker.ietf.org/doc/html/rfc7323" />
          <ref type="url"
id="https://web.archive.org/web/20151213072445/http://www.microsoft.com/en-
us/download/details.aspx?id=9152" />
          <ref type="url" id="https://www.fortiguard.com/psirt/FG-IR-16-090" />
        </refs>
      </nvt>
      <scan_nvt_version>2023-12-15T16:10:08Z</scan_nvt_version>
      <threat>Low</threat>
      <severity>2.6</severity>
      <qod>
        <value>80</value>
        <type />
      </qod>
```

```
      <original_threat>Low</original_threat>
      <original_severity>2.6</original_severity>
      <compliance>undefined</compliance>
    </result>
    <result id="59742992-42a4-4c64-8271-ff4c7e4b3ca2">
      <name>Weak MAC Algorithm(s) Supported (SSH)</name>
      <modification_time>2026-09-24T14:53:11Z</modification_time>
      <comment />
      <creation_time>2026-09-24T14:53:11Z</creation_time>
      <detection>
        <result id="6100d895-2d06-4556-a34f-302deb1a3a05">
          <details>
            <detail>
              <name>product</name>
              <value>cpe:/a:ietf:secure_shell_protocol</value>
            </detail>
            <detail>
              <name>location</name>
              <value>22/tcp</value>
            </detail>
            <detail>
              <name>source_oid</name>
              <value>1.3.6.1.4.1.25623.1.0.105565</value>
            </detail>
            <detail>
              <name>source_name</name>
              <value>SSH Protocol Algorithms Supported</value>
            </detail>
          </details>
        </result>
      </detection>
      <host>127.0.0.1<asset asset_id="a28c1a16-3ae8-405b-a0d5-d3851cffa5c1" />
        <hostname />
      </host>
      <port>22/tcp</port>
      <nvt oid="1.3.6.1.4.1.25623.1.0.105610">
        <type>nvt</type>
        <name>Weak MAC Algorithm(s) Supported (SSH)</name>
        <family>SSL and TLS</family>
        <cvss_base>2.6</cvss_base>
        <severities score="2.6">
          <severity type="cvss_base_v2">
            <origin />
            <date>2016-04-19T09:49:32Z</date>
            <score>2.6</score>
            <value>AV:N/AC:H/Au:N/C:P/I:N/A:N</value>
          </severity>
        </severities>
        <tags>cvss_base_vector=AV:N/AC:H/Au:N/C:P/I:N/A:N|summary=The remote SSH
server is configured to allow / support weak MAC
algorithm(s).|insight=|affected=|impact=|solution=Disable the reported weak MAC
algorithm(s).|vuldetect=Checks the supported MAC algorithms (client-to-server and server-to-
client) of the remote SSH server. Currently weak MAC algorithms are defined as the following: -
MD5 based algorithms - 96-bit based algorithms - 64-bit based algorithms - 'none'
algorithm|solution_type=Mitigation</tags>
        <solution type="Mitigation">Disable the reported weak MAC algorithm(s).</solution>
```

```
        <refs>
          <ref type="url" id="https://www.rfc-editor.org/rfc/rfc6668" />
          <ref type="url" id="https://www.rfc-editor.org/rfc/rfc4253#section-6.4" />
        </refs>
      </nvt>
      <scan_nvt_version>2024-06-14T05:05:48Z</scan_nvt_version>
      <threat>Low</threat>
      <severity>2.6</severity>
      <qod>
        <value>80</value>
        <type />
      </qod>
      <original_threat>Low</original_threat>
      <original_severity>2.6</original_severity>
      <compliance>undefined</compliance>
    </result>
    <result id="f163b377-d743-4cda-a082-9dd17c1e7a88">
      <name>ICMP Timestamp Reply Information Disclosure</name>
      <modification_time>2026-09-24T14:52:51Z</modification_time>
      <comment />
      <creation_time>2026-09-24T14:52:51Z</creation_time>
      <host>127.0.0.1<asset asset_id="a28c1a16-3ae8-405b-a0d5-d3851cffa5c1" />
        <hostname />
      </host>
      <port>general/icmp</port>
      <nvt oid="1.3.6.1.4.1.25623.1.0.103190">
        <type>nvt</type>
        <name>ICMP Timestamp Reply Information Disclosure</name>
        <family>General</family>
        <cvss_base>2.1</cvss_base>
        <severities score="2.1">
          <severity type="cvss_base_v2">
            <origin />
            <date>2011-07-15T11:32:07Z</date>
            <score>2.1</score>
            <value>AV:L/AC:L/Au:N/C:P/I:N/A:N</value>
          </severity>
        </severities>
        <tags>cvss_base_vector=AV:L/AC:L/Au:N/C:P/I:N/A:N|summary=The remote host
responded to an ICMP timestamp request.|insight=The Timestamp Reply is an ICMP message
which replies to a Timestamp message. It consists of the originating timestamp sent by the sender
of the Timestamp as well as a receive timestamp and a transmit timestamp.|affected=|impact=This
information could theoretically be used to exploit weak time-based random number generators in
other services.|solution=Various mitigations are possible: - Disable the support for ICMP
timestamp on the remote host completely - Protect the remote host by a firewall, and block ICMP
packets passing through the firewall in either direction (either completely or only for untrusted
networks)|vuldetect=Sends an ICMP Timestamp (Type 13) request and checks if a Timestamp
Reply (Type 14) is received.|solution_type=Mitigation</tags>
        <solution type="Mitigation">Various mitigations are possible: - Disable the support for
ICMP timestamp on the remote host completely - Protect the remote host by a firewall, and block
ICMP packets passing through the firewall in either direction (either completely or only for
untrusted networks)</solution>
        <refs>
          <ref type="cve" id="CVE-1999-0524" />
          <ref type="url" id="https://datatracker.ietf.org/doc/html/rfc792" />
          <ref type="url" id="https://datatracker.ietf.org/doc/html/rfc2780" />
```

```
          <ref type="cert-bund" id="CB-K15/1514" />
          <ref type="cert-bund" id="CB-K14/0632" />
          <ref type="dfn-cert" id="DFN-CERT-2014-0658" />
        </refs>
      </nvt>
      <scan_nvt_version>2025-01-21T05:37:33Z</scan_nvt_version>
      <threat>Low</threat>
      <severity>2.1</severity>
      <qod>
        <value>80</value>
        <type />
      </qod>
      <original_threat>Low</original_threat>
      <original_severity>2.1</original_severity>
      <compliance>undefined</compliance>
    </result>
  </results>
 </report>
</report>
```

C.3 Scan authentifié (authentification SSH réussie ; 2 résultats propres au scan authentifié)

Les trois autres résultats retenus du scan authentifié (TCP Timestamps, Weak MAC Algorithm(s), ICMP Timestamp Reply) sont identiques à ceux de l'annexe C.2 ; seuls les deux résultats propres au scan authentifié sont reproduits ici.

```
<!-- Extrait de : report-Scan OpenVAS authentifié.xml (format Anonymous XML, filtre
min_qod=70) -->
<report id="72045a08-32b5-49a8-88f6-b88de029c1d1">
  <creation_time>2026-09-24T15:09:30Z</creation_time>
  <report>
    <scan_run_status>Done</scan_run_status>
    <timestamp>2026-09-24T15:09:30Z</timestamp>
    <scan_start>2026-09-24T15:09:45Z</scan_start>
    <scan_end>2026-09-24T15:29:20Z</scan_end>
    <timezone_abbrev>UTC</timezone_abbrev>
    <task id="7dddf2d8-4896-4c78-bd58-8d175814b03e">
      <comment />
      <target id="61b90691-79ee-4c7e-abec-f2cc92bde356">
        <trash>0</trash>
        <name>TP2 - cible auth</name>
        <comment />
      </target>
      <progress>100</progress>
    </task>
    <result_count>232<full>232</full>
      <filtered>5</filtered>
      <critical>
        <full>23</full>
        <filtered>0</filtered>
      </critical>
      <hole deprecated="1">
        <full>56</full>
        <filtered>0</filtered>
      </hole>
      <high>
        <full>56</full>
        <filtered>0</filtered>
      </high>
      <info deprecated="1">
        <full>12</full>
        <filtered>4</filtered>
      </info>
      <low>
        <full>12</full>
        <filtered>4</filtered>
      </low>
      <log>
        <full>40</full>
        <filtered>0</filtered>
      </log>
      <warning deprecated="1">
        <full>101</full>
        <filtered>1</filtered>
      </warning>
      <medium>
```

```
      <full>101</full>
      <filtered>1</filtered>
    </medium>
    <false_positive>
      <full>0</full>
      <filtered>0</filtered>
    </false_positive>
  </result_count>
  <filters><term>apply_overrides=0 levels=chml rows=1000 min_qod=70 first=1 sort-
reverse=severity result_hosts_only=0 notes=1 overrides=1</term></filters>
  <host>
    <ip>127.0.0.1</ip>
    <start>2026-09-24T15:10:33Z</start>
    <end>2026-09-24T15:29:15Z</end>
    <detail>
      <name>ports</name>
      <value>22,80</value>
      <source>
        <type>nvt</type>
        <name>1.3.6.1.4.1.25623.1.0.900239</name>
        <description>Check Open TCP Ports</description>
      </source>
      <extra />
    </detail>
    <detail>
      <name>best_os_txt</name>
      <value>Ubuntu 22.04 LTS</value>
      <source>
        <type>nvt</type>
        <name>1.3.6.1.4.1.25623.1.0.50282;</name>
        <description>Determine OS and list of installed packages via SSH login</description>
      </source>
      <extra />
    </detail>
    <detail>
      <name>Auth-SSH-Success</name>
      <value>Protocol SSH, Port 22, User auditeur</value>
      <source>
        <type>nvt</type>
        <name>1.3.6.1.4.1.25623.1.0.90022</name>
        <description />
      </source>
      <extra />
    </detail>
  </host>
  <results max="1000" start="1">
    <result id="16c32f51-cdd8-4192-87c4-817fd4531360">
      <name>Missing Linux Kernel mitigations for 'VMScape' hardware vulnerability</name>
      <modification_time>2026-09-24T15:13:14Z</modification_time>
      <comment />
      <creation_time>2026-09-24T15:13:14Z</creation_time>
      <detection>
        <result id="fa518840-a5f4-486d-8e30-25dfebe6b7b6">
          <details>
            <detail>
              <name>product</name>
```

```
            <value>cpe:/a:linux:kernel</value>
          </detail>
          <detail>
            <name>location</name>
            <value>general/tcp</value>
          </detail>
          <detail>
            <name>source_oid</name>
            <value>1.3.6.1.4.1.25623.1.0.108765</value>
          </detail>
          <detail>
            <name>source_name</name>
            <value>Detection of Linux Kernel mitigation status for hardware
vulnerabilities</value>
          </detail>
        </details>
      </result>
    </detection>
    <host>127.0.0.1<asset asset_id="06726631-8ea4-493c-8807-9d1bb4743d2e" />
      <hostname />
    </host>
    <port>general/tcp</port>
    <nvt oid="1.3.6.1.4.1.25623.1.0.119212">
      <type>nvt</type>
      <name>Missing Linux Kernel mitigations for 'VMScape' hardware vulnerability</name>
      <family>General</family>
      <cvss_base>5.5</cvss_base>
      <severities score="5.5">
        <severity type="cvss_base_v3">
          <origin>NVD</origin>
          <date>2026-01-16T20:25:45Z</date>
          <score>5.5</score>
          <value>CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H</value>
        </severity>
      </severities>

<tags>cvss_base_vector=CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H|summary=The
remote host is missing one or more known mitigation(s) on Linux Kernel side for the referenced
'VMScape' hardware vulnerability.|insight=VMScape is a vulnerability that may allow a guest to
influence the branch prediction in host userspace. Even if a hypervisor may not have any sensitive
data like disk encryption keys, guest-userspace may be able to attack the guest-kernel using the
hypervisor as a confused deputy.|affected=Various Intel and AMD CPUs. Please see the
references for the full list of affected CPUs. It particularly affects hypervisors like
QEMU.|impact=|solution=The following solutions exist: - Update to a more recent Linux Kernel
to receive mitigations on Kernel level and info about the mitigation status from it - Enable the
mitigation(s) in the Linux Kernel (might be disabled depending on the configuration) Additional
possible mitigations (if provided by the vendor) are to: - install a Microcode update - update the
BIOS of the Mainboard Note: Please create an override for this result if one of the following
applies: - the sysfs file is not available but other mitigations like a Microcode update is already in
place - the sysfs file is not available but the CPU of the host is not affected - the reporting of the
Linux Kernel is not correct (this is out of the control of this VT) - the target host is running
Xen|vuldetect=Checks previous gathered information on the mitigation status reported by the
Linux Kernel.|solution_type=VendorFix</tags>
```

```
        <solution type="VendorFix">The following solutions exist: - Update to a more recent
Linux Kernel to receive mitigations on Kernel level and info about the mitigation status from it -
Enable the mitigation(s) in the Linux Kernel (might be disabled depending on the configuration)
Additional possible mitigations (if provided by the vendor) are to: - install a Microcode update -
update the BIOS of the Mainboard Note: Please create an override for this result if one of the
following applies: - the sysfs file is not available but other mitigations like a Microcode update is
already in place - the sysfs file is not available but the CPU of the host is not affected - the
reporting of the Linux Kernel is not correct (this is out of the control of this VT) - the target host is
running Xen</solution>
        <refs>
          <ref type="cve" id="CVE-2025-40300" />
          <ref type="url" id="https://docs.kernel.org/admin-guide/hw-vuln/vmscape.html" />
          <ref type="url" id="https://docs.kernel.org/admin-guide/hw-
vuln/attack_vector_controls.html" />
          <ref type="url" id="https://comsec.ethz.ch/research/microarch/vmscape-exposing-and-
exploiting-incomplete-branch-predictor-isolation-in-cloud-environments/" />
          <ref type="url" id="https://virtualize.sh/blog/vmscape-and-why-xen-dodged-it/" />
          <ref type="cert-bund" id="WID-SEC-2026-2253" />
          <ref type="cert-bund" id="WID-SEC-2026-0349" />
          <ref type="cert-bund" id="WID-SEC-2025-2040" />
          <ref type="dfn-cert" id="DFN-CERT-2026-0053" />
          <ref type="dfn-cert" id="DFN-CERT-2025-3515" />
          <ref type="dfn-cert" id="DFN-CERT-2025-3308" />
          <ref type="dfn-cert" id="DFN-CERT-2025-3306" />
          <ref type="dfn-cert" id="DFN-CERT-2025-3244" />
          <ref type="dfn-cert" id="DFN-CERT-2025-3243" />
          <ref type="dfn-cert" id="DFN-CERT-2025-3242" />
          <ref type="dfn-cert" id="DFN-CERT-2025-3176" />
          <ref type="dfn-cert" id="DFN-CERT-2025-3175" />
          <ref type="dfn-cert" id="DFN-CERT-2025-3134" />
          <ref type="dfn-cert" id="DFN-CERT-2025-3133" />
          <ref type="dfn-cert" id="DFN-CERT-2025-3125" />
          <ref type="dfn-cert" id="DFN-CERT-2025-3116" />
          <ref type="dfn-cert" id="DFN-CERT-2025-3109" />
          <ref type="dfn-cert" id="DFN-CERT-2025-3108" />
          <ref type="dfn-cert" id="DFN-CERT-2025-3057" />
          <ref type="dfn-cert" id="DFN-CERT-2025-3032" />
          <ref type="dfn-cert" id="DFN-CERT-2025-3031" />
          <ref type="dfn-cert" id="DFN-CERT-2025-2529" />
        </refs>
      </nvt>
      <scan_nvt_version>2026-07-10T06:54:17Z</scan_nvt_version>
      <threat>Medium</threat>
      <severity>5.5</severity>
      <qod>
        <value>80</value>
        <type />
      </qod>
      <original_threat>Medium</original_threat>
      <original_severity>5.5</original_severity>
      <compliance>undefined</compliance>
    </result>
    <result id="13006a86-3a69-4988-b2d9-f7bc7de25d64">
      <name>Missing Linux Kernel mitigations for 'TSA' hardware vulnerabilities (AMD-SB-
7029)</name>
      <modification_time>2026-09-24T15:13:14Z</modification_time>
```

```
      <comment />
      <creation_time>2026-09-24T15:13:14Z</creation_time>
      <detection>
        <result id="fa518840-a5f4-486d-8e30-25dfebe6b7b6">
          <details>
            <detail>
              <name>product</name>
              <value>cpe:/a:linux:kernel</value>
            </detail>
            <detail>
              <name>location</name>
              <value>general/tcp</value>
            </detail>
            <detail>
              <name>source_oid</name>
              <value>1.3.6.1.4.1.25623.1.0.108765</value>
            </detail>
            <detail>
              <name>source_name</name>
              <value>Detection of Linux Kernel mitigation status for hardware
vulnerabilities</value>
            </detail>
          </details>
        </result>
      </detection>
      <host>127.0.0.1<asset asset_id="06726631-8ea4-493c-8807-9d1bb4743d2e" />
        <hostname />
      </host>
      <port>general/tcp</port>
      <nvt oid="1.3.6.1.4.1.25623.1.0.119211">
        <type>nvt</type>
        <name>Missing Linux Kernel mitigations for 'TSA' hardware vulnerabilities (AMD-SB-
7029)</name>
        <family>General</family>
        <cvss_base>3.8</cvss_base>
        <severities score="3.8">
          <severity type="cvss_base_v2">
            <origin />
            <date>2025-10-28T14:30:23Z</date>
            <score>3.8</score>
            <value>AV:L/AC:H/Au:S/C:C/I:N/A:N</value>
          </severity>
        </severities>
```

<tags>cvss_base_vector=AV:L/AC:H/Au:S/C:C/I:N/A:N|summary=The remote host is missing one or more known mitigation(s) on Linux Kernel side for the referenced 'AMD Transient Scheduler Attacks' (TSA) hardware vulnerabilities.|insight=The following flaws exist: - CVE-2024-36348: A transient execution vulnerability may allow a user process to infer the control registers speculatively even if UMIP[3] feature is enabled, potentially resulting in information leakage. - CVE-2024-36349: A transient execution vulnerability may allow a user process to infer TSC_AUX even when such a read is disabled, potentially resulting in information leakage. - CVE-2024-36350: A transient execution vulnerability may allow an attacker to infer data from previous stores, potentially resulting in the leakage of privileged information. - CVE-2024-36357: A transient execution vulnerability may allow an attacker to infer data in the L1D cache, potentially resulting in the leakage of sensitive information across privileged boundaries.|affected=Various AMD CPUs. Please see the references for the full list of affected CPUs.|impact=|solution=The following solutions exist: - Update to a more recent Linux Kernel to receive mitigations on Kernel level and info about the mitigation status from it - Enable the mitigation(s) in the Linux Kernel (might be disabled depending on the configuration) Additional possible mitigations (if provided by the vendor) are to: - install a Microcode update - update the BIOS of the Mainboard Note: Please create an override for this result if one of the following applies: - the sysfs file is not available but other mitigations like a Microcode update is already in place - the sysfs file is not available but the CPU of the host is not affected - the reporting of the Linux Kernel is not correct (this is out of the control of this VT)|vuldetect=Checks previous gathered information on the mitigation status reported by the Linux Kernel.|solution_type=VendorFix</tags>
<solution type="VendorFix">The following solutions exist: - Update to a more recent Linux Kernel to receive mitigations on Kernel level and info about the mitigation status from it - Enable the mitigation(s) in the Linux Kernel (might be disabled depending on the configuration) Additional possible mitigations (if provided by the vendor) are to: - install a Microcode update - update the BIOS of the Mainboard Note: Please create an override for this result if one of the following applies: - the sysfs file is not available but other mitigations like a Microcode update is already in place - the sysfs file is not available but the CPU of the host is not affected - the reporting of the Linux Kernel is not correct (this is out of the control of this VT)</solution>
<refs>
<ref type="cve" id="CVE-2024-36348" />
<ref type="cve" id="CVE-2024-36349" />
<ref type="cve" id="CVE-2024-36350" />
<ref type="cve" id="CVE-2024-36357" />
<ref type="url" id="https://docs.kernel.org/admin-guide/hw-vuln/index.html" />
<ref type="url" id="https://docs.kernel.org/admin-guide/hw-vuln/attack_vector_controls.html" />
<ref type="url" id="https://www.amd.com/en/resources/product-security/bulletin/amd-sb-7029.html" />
<ref type="cert-bund" id="WID-SEC-2026-2253" />
<ref type="cert-bund" id="WID-SEC-2025-1850" />
<ref type="cert-bund" id="WID-SEC-2025-1502" />
<ref type="dfn-cert" id="DFN-CERT-2026-2914" />
<ref type="dfn-cert" id="DFN-CERT-2026-1712" />
<ref type="dfn-cert" id="DFN-CERT-2025-3377" />
<ref type="dfn-cert" id="DFN-CERT-2025-3133" />
<ref type="dfn-cert" id="DFN-CERT-2025-2173" />
<ref type="dfn-cert" id="DFN-CERT-2025-1912" />
<ref type="dfn-cert" id="DFN-CERT-2025-1908" />
<ref type="dfn-cert" id="DFN-CERT-2025-1839" />
<ref type="dfn-cert" id="DFN-CERT-2025-1835" />
<ref type="dfn-cert" id="DFN-CERT-2025-1833" />
<ref type="dfn-cert" id="DFN-CERT-2025-1825" />
<ref type="dfn-cert" id="DFN-CERT-2025-1811" />
</refs>
</nvt>

```
      <scan_nvt_version>2026-07-10T06:54:17Z</scan_nvt_version>
      <threat>Low</threat>
      <severity>3.8</severity>
      <qod>
        <value>80</value>
        <type />
      </qod>
      <original_threat>Low</original_threat>
      <original_severity>3.8</original_severity>
      <compliance>undefined</compliance>
    </result>
  </results>
 </report>
</report>
```

Annexe D — Index des preuves du TP 2

Fichier du dossier	Contenu	Utilisé dans
Architecture du Laboratoire.png	Topologie du laboratoire	Figure 1
SSH sur le serveur.png	Connexion SSH du compte auditeur à srv-linux	Figure 2
Nmap (découverte et services), dans le laboratoire.txt	Sorties des quatre commandes Nmap	§ 3, annexe A
empreintes.txt	Empreintes SHA-256 des sorties Nmap	Annexe B
Créer Scan non authentifié.png · Créer Scan authentifié.png	Création des deux cibles OpenVAS	Figure 4
Compte lecture seule - scan authentifié TP2.png	Identifiant SSH « auditeur »	Figure 5
scan OpenVAS non authentifié.png · … Full and fast.png	Création de la tâche non authentifiée	Figure 6
scan OpenVAS non authentifié puis authentifié sur une cible.png	Liste des deux tâches terminées	Figure 7
scan OpenVAS non authentifié report.png	Rapport du scan non authentifié	Figure 8
scan OpenVAS authentifié report.png	Rapport du scan authentifié	Figure 9
Report download anonymus.png	Export du rapport (Anonymous XML, min_qod=70)	Figure 10
report-Scan OpenVAS non authentifié.xml	Rapport XML du scan non authentifié	Annexe C
report-Scan OpenVAS authentifié.xml	Rapport XML du scan authentifié	Annexe C

Les éléments de préparation du laboratoire (checklist de configuration initiale et capture de l'installation de GVM) ne sont pas reproduits, car ils contiennent des identifiants.